

node-re2: Out-of-bounds heap read in ``replace`/`split`` via a ``Buffer`` ending in a truncated multi-byte UTF-8 character → adjacent heap memory disclosed to JavaScript

Report Type: Weekly · Generated: August 07, 2026 05:05 UTC · Coverage: Aug 06 - Aug 07, 2026

1 Total Advisories	0 Critical	0 High	1 Medium
MEDIUM Severity	5.1 CVSS / Risk Score	TLP: CLEAR TLP Classification	PRO Customer Tier

Executive Summary

Summary ``re2`` infers a character's byte length from its UTF-8 lead byte alone, with no bound on the bytes actually remaining in the input. ``Buffer`` arguments reach the native layer verbatim — only strings are re-encoded into well-formed UTF-8 — so a ``Buffer`` whose last byte is a multi-byte lead promises continuation bytes that are not there, and the result builders read up to 3 bytes past the end of the buffer. In ``replace()`` and ``split()`` those bytes are copied into the returned ``Buffer``, disclosing adjacent heap memory to JavaScript. The trigger is deterministic and requires no special heap grooming. Only ``Buffer`` input is affected. String input was never at risk: re-encoding guarantees every multi-byte sequence is complete. ## Root cause ``getUtf8CharSize`` maps a lead byte to a length of 1–4 and never sees the input size: ````cpp // lib/wrapped_re2.h inline size_t getUtf8CharSize(char ch) { return ((0xE5000000 >> ((ch >> 3) & 0x1E)) & 3) + 1; }```` Callers then read tha

CONFIDENTIALITY NOTICE: This report is classified PRO tier and intended exclusively for the named recipient. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited. © 2026 CYBERDUDEBIVASH SENTINEL APEX. All rights reserved.

High-priority advisories ranked by CVSS score, exploitability, and actor attribution.

Advisory Title	Severity	CVSS	EPSS	AI Summary
node-re2: Out-of-bounds heap read in `replace`/`split` methods	MEDIUM	5.1	-	## Summary `re2` infers a character's byte length from its UTF-8 lead byte along with the number of bytes actually remaining i

Technique density score: 0.0 · Techniques observed: 0 · Tactics covered: 0

MITRE ATT&CK techniques pending analyst enrichment. Deploy detection rules from Section 6 to identify related activity.

Attribution analysis across advisories in this report period.

IOC extraction for this advisory is pending enrichment pipeline completion. PRO subscribers receive real-time IOC push to SIEM/SOAR via the SENTINEL APEX webhook at: **GET /api/v1/intelliocs?advisory={id}**. Full IOC packages include IPv4, domain, SHA256, and URL indicators with confidence scores, first-seen timestamps, and STIX 2.1 formatted bundles.

Detection Engineering

Deploy these production-ready detection rules into your SIEM platform to identify exploitation attempts in real time. Compatible with Microsoft Sentinel, Splunk ES, and any Sigma-compatible platform.

Sigma Rule - Webserver / Process Monitoring

```
title: SENTINEL APEX - Heap Overflow Exploitation Attempt
id: cdb-cdb-advisory-det
status: experimental
description: |
  Detects exploitation attempts targeting CDB-ADVISORY (heap-based overflow).
  Monitors for anomalous process crashes and memory allocation failures.
references:
  - https://intel.cyberdudebivash.com
author: CyberDudeBivash SENTINEL APEX
date: 2026/08/07
tags:
  - attack.initial_access
  - attack.t1190
  - attack.execution
  - attack.t1203
logsource:
category: process_creation
product: windows
detection:
  selection_crash:
    EventID: 1000
    ApplicationName|contains|any:
      - 'node-re2:'
    selection_wer:
      EventID: 1001
      AppPath|contains|any:
        - 'node-re2:'
    condition: selection_crash OR selection_wer
  falsepositives:
    - Legitimate software bugs / crash reporting
level: medium
```

Microsoft Sentinel - KQL Query

```
// SENTINEL APEX - node-re2: Out-of-bounds heap read in `replace`/`split` via a `Buffer` ending in a truncated
multi-byte UTF-8 character → adjacent heap memory disclosed to JavaScript
// Advisory | Microsoft Sentinel KQL
let time_window = ago(24h);
SecurityAlert
| where TimeGenerated > time_window
| where Description has "node-re2: Out-of-bounds heap read in `re"
or AlertName has "node-re2: Out-of-bounds heap read in `re"
or ExtendedProperties has "node-re2: Out-of-bounds heap read in `re"
| extend Rule = "APEX-ADVISORY", Severity = "MEDIUM"
| project TimeGenerated, AlertName, AlertSeverity, Entities, Description, Rule, Severity
| order by TimeGenerated desc
```

Incident Response Playbook

Phase 1 - 0-24 Hours (Containment)

- 1. Activate IR team; assign lead analyst and executive sponsor.
- 2. Isolate or WAF-shield node instances exposed to the internet.
- 3. Enable verbose access logging on all node endpoints immediately.
- 4. Pull last 72h of web server and application logs for forensic baselining.
- 5. Check SENTINEL APEX IOC feeds and SIEM alerts for exploitation hits in your environment.
- 6. Notify relevant internal stakeholders and legal / compliance team.

Phase 2 - 24-72 Hours (Eradication)

- 1. Apply vendor patch for node or implement recommended mitigation.
- 2. Deploy Sigma and KQL detection rules from Section 6 across all SIEM platforms.
- 3. Rotate all API keys, service account credentials, and session tokens.
- 4. Conduct forensic timeline reconstruction for potential compromise window.
- 5. Validate patch deployment across 100% of affected instances via asset inventory.

Phase 3 - 7 Days (Recovery & Hardening)

- 1. Conduct post-incident review and update incident response runbooks.
- 2. Threat hunt for lateral movement or persistence artifacts using MITRE ATT&CK mapping.
- 3. Update asset inventory with patched version information and closure evidence.
- 4. Submit findings to internal risk register and CISO dashboard.
- 5. Schedule follow-up vulnerability scan to confirm remediation completeness.

Financial Impact Analysis (FAIR Model)

\$150K - \$900K Breach Cost Range (FAIR)	\$380K IBM Cost of Breach 2025 Median	\$120K/day Business Interruption Cost	\$85K Regulatory Fine Exposure
--	---	---	--

Medium severity events require internal investigation and targeted customer notification. Average cost includes 340 hours of engineering time.

Remediation Cost Estimate: \$55K · Includes engineering time, IR retainer activation, forensic investigation, and customer notification costs.

Regulatory & Compliance Implications

Organizations processing this advisory must evaluate obligations under applicable regulatory frameworks. The table below maps this threat to relevant compliance requirements.

Framework	Reference	Obligation
PCI-DSS v4.0	Req. 6.3.3	Non-critical patches applied within 3 months
NIST CSF 2.0	ID.RA / PR.PS	Vulnerability assessment and platform security policies
ISO 27001:2022	A.8.8	Vulnerability management programme with documented remediation timelines

Actionable Recommendations

Prioritized defensive actions based on this period's intelligence.

1. Monitor node-re2: Out-of-bounds heap read in `replace`/`split` via a `Buffer` ending in a truncated multi-byte UTF-8 character → adjacent heap memory disclosed to JavaScript for escalation.
2. Apply patches in next maintenance window.
3. Apply vendor patch for node-re2: Out-of-bounds heap read in `replace`/`split` via a `Buffer` ending in a truncated multi-byte UTF-8 character → adjacent heap memory disclosed to JavaScript immediately - check NVD for official fix guidance.
4. Enable enhanced logging and alerting on all systems running affected software versions.
5. Deploy the Sigma detection rule from this report into your SIEM platform (Sentinel / Splunk / Elastic).
6. Audit all internet-facing instances of affected products and confirm patch deployment.
7. Conduct a threat hunt using MITRE ATT&CK techniques mapped in this advisory.

Appendix - Report Metadata & Legal

Field	Value
Report ID	intel--eedd1cc59150f7f54a415936
Report Type	Weekly
Platform	CYBERDUDEBIVASH SENTINEL APEX v166.0 GOD-MODE
Generated At	2026-08-07T05:05:12.55452
Customer Tier	PRO
Customer Email	-
TLP	TLP: CLEAR
STIX Version	2.1
ATT&CK Version	v15

Legal & Usage Notice

This threat intelligence report is produced by CYBERDUDEBIVASH SENTINEL APEX, operated by Bivash Nath (GSTIN: 21ARKPN8270G1ZP). All intelligence is aggregated from public vulnerability databases (NVD, CVSS), threat feeds, and proprietary AI enrichment pipelines. This report is provided AS-IS for informational and defensive security purposes only. CYBERDUDEBIVASH accepts no liability for actions taken based on this intelligence. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited without written consent. For licensing inquiries: enterprise@cyberdudebivash.com